QUESTION 3: COMMON SOC SEVERITY LEVELS

DG Interns Hub Cybersecurity Internship – Week 5 Submission

Student Name: Gunjan **Track:** SOC Analyst Tier 1 **Topic:** Alert Prioritization & Severity Classification

1. OVERVIEW OF SOC SEVERITY LEVELS

Security events in a SOC are assigned **Severity Levels** to categorize their risk, urgency, and operational priority. Assigning accurate severity levels prevents analyst confusion and guarantees that critical incidents receive immediate containment, meeting strict Service Level Agreements (SLAs).

2. SEVERITY COMPARISON TABLE

Severity	Definition & Urgency	Typical SLA	Practical SOC Example
CRITICAL	Active, catastrophic security incident impacting core infrastructure or confidential corporate data. Immediate all-hands containment required.	< 15 mins	Ransomware actively encrypting files on a primary Active Directory Domain Controller.
HIGH	High probability of active compromise or unauthorized privilege escalation on key assets. Threat actor confirmed on host.	< 30 mins	LSASS credential dumping (Mimikatz execution) detected on an executive machine.
MEDIUM	Suspicious activity requiring timely investigation. Potential early-stage attack vector or policy violation.	< 2 hours	50 failed login attempts followed by 1 successful login from an unexpected geographical location.
LOW	Minor anomaly or non-critical policy violation. Minimal business or security impact.	< 8 hours	An unauthorized USB storage device plugged into a non-sensitive workstation.
INFO	Operational audit log event. No threat indicated; retained for baseline context and compliance auditing.	N/A (No SLA)	A regular user successfully resetting their domain password via the self-service portal.

3. KEY FACTORS USED TO DETERMINE SEVERITY

Alert severity is not determined by security tools alone; analysts evaluate multiple contextual factors:

Asset Criticality: The importance of the host involved. An alert on a public payment server or Domain Controller carries far higher severity than the same alert on an isolated sandbox machine. Potential financial, operational, or legal damage caused if the threat succeeds (e.g., data exfiltration vs. temporary service disruption). Availability of public exploits (CVE severity), vulnerability patch status, and exposure level of the system. Stage of the attack lifecycle (MITRE ATT&CK). Execution or Lateral Movement yields higher severity than initial external scanning. High-fidelity alerts validated by threat intelligence carry higher severity than broad heuristic warnings. **Business Impact:Likelihood of Exploitation:Attacker Progression:Evidence Confidence:**

4. PRACTICAL SOC SEVERITY SCENARIOS

Scenario A: Critical Severity Evaluation

Event: Mass file renaming and `.locked` extensions observed on `FILE-SHARE-01`.

Assessment: Asset is a centralized file server (High Criticality); impact is organization-wide data loss (High Impact). Classified instantly as **CRITICAL**. Host isolated immediately via EDR.

Scenario B: Medium Severity Evaluation

Event: Port scan originating from internal IP `10.0.2.45` targeting internal servers.

Assessment: Indicates potential internal reconnaissance (Discovery stage), but no privilege escalation or active malware observed. Classified as **MEDIUM** for standard L1 triage within SLA.

5. TERMINOLOGY & REFERENCES

SLA (Service Level Agreement): Mandated timeframe to acknowledge and triage alerts based on severity. **Asset Criticality:** Security classification ranking system systems by business value.

References:

• FIRST Common Vulnerability Scoring System (CVSS) v3.1: **https://www.first.org/cvss/**
• SANS Institute Incident Management Handbook: **https://www.sans.org/**